

Security Audit

Rank.Trading (DeFi)

Table of Contents

Executive Summary	4
Project Context	4
Audit scope	7
Security Rating	8
Intended Smart Contract Functions	9
Code Quality	10
Audit Resources	10
Dependencies	10
Severity Definitions	11
Status Definitions	12
Audit Findings	13
Centralisation	16
Conclusion	17
Our Methodology	18
Disclaimers	20
About Hashlock	21

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The Rank Trading team partnered with Hashlock to conduct a security audit of their RankFactory.sol, RankStrategy.sol, and RankToken.sol smart contracts. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

Rank is a decentralized finance (DeFi) platform that empowers users to create, deploy, and invest in automated trading strategies without any coding knowledge. By providing a user-friendly interface and advanced tools like AI-powered testing and risk management, Rank simplifies DeFi trading and makes it accessible to everyone. Rank envisions the creation of a robust, decentralized, and automated investment platform, with the goal of bringing some of the standard traditional financial products into the DeFi environment. The platform is the only one offering no-code automated DeFi trading and a comprehensive ranking tool. This unique combination allows users to create, deploy, and rank their trading strategies without any coding experience.

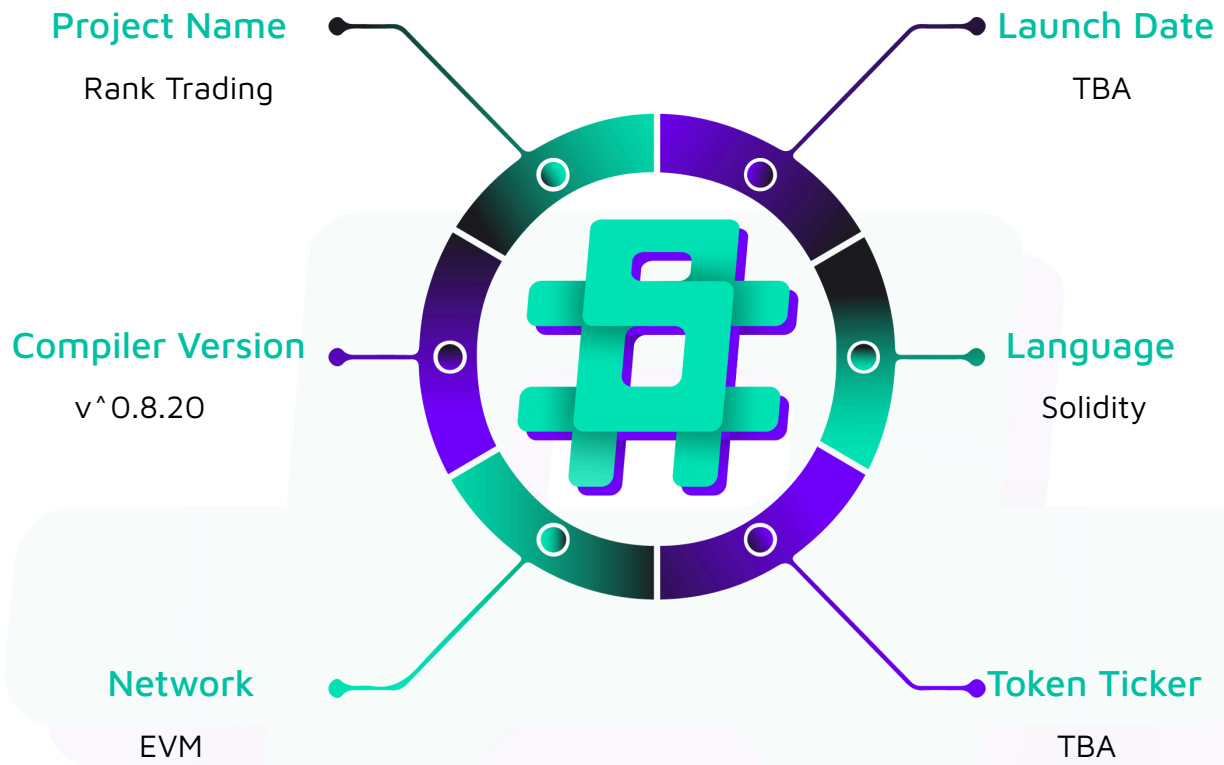
Project Name: Rank Trading

Compiler Version: ^0.8.20

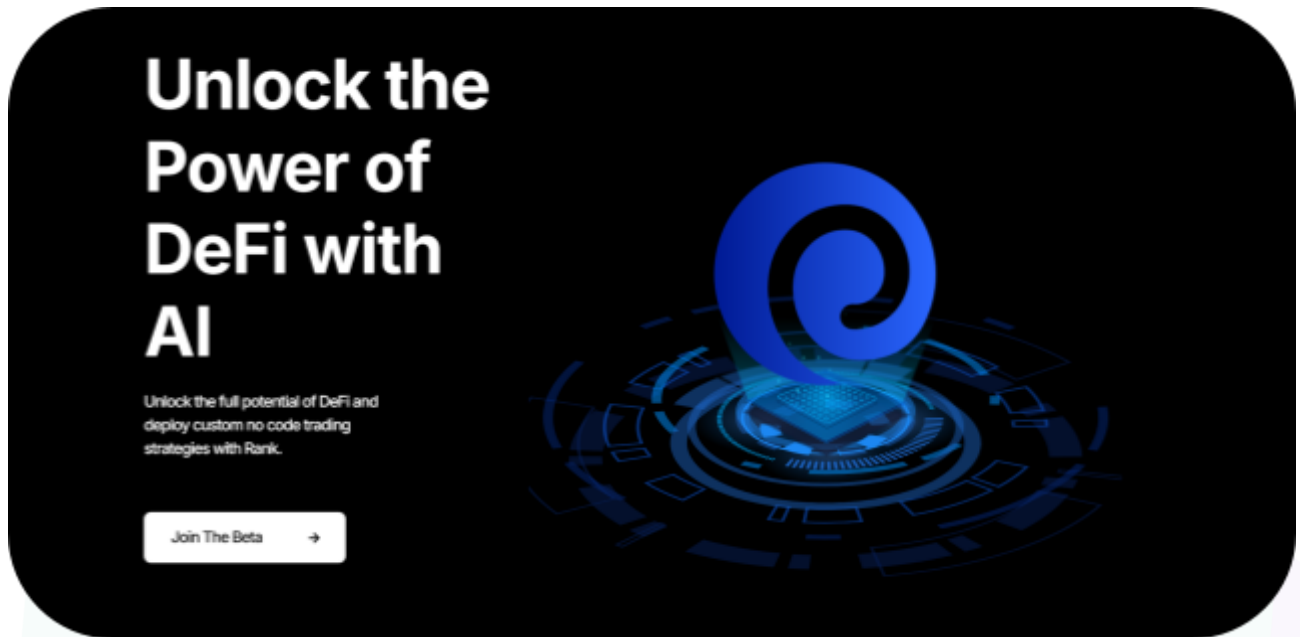
Website: www.rank.trading

Logo:



Visualised Context:

Project Visuals:



Unlocking the Potential of DeFi for Non-Coders

In 2024, the DeFi market is projected to reach an impressive US\$26,170.0 million. At our platform, we empower users by providing cutting-edge no-code tools that enable anyone to create automated DeFi trading strategies, regardless of coding experience. These tools allow users to build mini hedge funds, where others can invest and earn from these strategies. Our platform also features a comprehensive ranking system, letting users track their performance and see how they stack up against the competition. Join us to take full advantage of the booming DeFi market and elevate your trading game!

0.26% | **22M+**
User penetration in 2024 | DeFi users projected by 2028



Audit scope

We at Hashlock audited the solidity code within the Rank Trading project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	Rank Trading Smart Contracts
Platform	EVM / Solidity
Audit Date	January, 2025
Contract 1	RankFactory.sol
Contract 1 MD5 Hash	da7490ac23d7c08985919983e6127df9
Contract 2	RankStrategy.sol
Contract 2 MD5 Hash	73af5b85b5f23f53743e702c943c5e99
Contract 3	RankToken.sol
Contract 3 MD5 Hash	60e37b18a8aca1e13ec5a577edeccf39
GitHub Commit Hash	4b93f40358beb55a4644ae420d7903c7d339f17d

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces, and the protocol uses a list of Open Zeppelin contracts. We initially identified some significant vulnerabilities that have since been addressed.



Not Secure

Vulnerable

Secure

Hashlocked

The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Audit Findings](#) section. The general security overview is presented in the [Standardised Checks](#) section and the project's contract functionality is presented in the [Intended Smart Contract Functions](#) section.

All vulnerabilities initially identified have now been resolved and acknowledged.

Hashlock found:

1 Medium severity vulnerability

1 Low severity vulnerability

1 Gas Optimisation

1 QA

Caution: *Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.*

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
RankFactory.sol Facilitates the creation and management of RankStrategy instances	Contract achieves this functionality.
RankStrategy.sol Manages the strategies for the Rank Trading Platform, allowing users to invest, unlock, and withdraw assets based on predefined strategies	Contract achieves this functionality.
RankToken.sol ERC20 token for the Rank Trading Platform	Contract achieves this functionality.

Code Quality

This audit scope involves the smart contracts of the Rank Trading project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring was required.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the Rank Trading project smart contract code in the form of Github access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Medium

[M-01] RankStrategy#_handleRequestInvests - Denial of Service risk due to gas limit while handling all requests investments

Description

Because the `_invest` function allows for an unlimited number of investment requests to be added, when the `_handleRequestInvests` function iterates over the `requestedInvestsCount` value while handling all requested investments, the contract may revert when the backend manager interacts with the `updateStrategyValues` function.

Vulnerability Details

The `_handleRequestInvests` function loops over all requested investments to be handled:

```
for (uint256 t = 0; t < requestedInvestsCount; t++) {  
    ...  
}
```

Depending on the number of requested investments that the contract supports, calls to `_handleRequestInvests` may run out of gas, resulting in a denial of service of all external-facing functions.

Recommendation

It's recommended that the `RankStrategy` contract allows for the specification of an offset and length so that requested investments can be handled in batches or limit the number of investments to be added.

Status

Resolved

Low

[L-01] RankStrategy#constructor - Lack of `_disableInitializers()` call in implementation contract

Description

The `RankStrategy` contract is an upgradeable smart contract.

The implementation contracts allow anyone to call the `initialize()` function due to an absence of a `_disableInitializers()` call in the constructor.

Recommendation

It's recommended to call `_disableInitializers()` in the constructor.

```
constructor() {  
    _disableInitializers();  
}
```

Status

Resolved

Gas

[G-01] RankStrategy#initialize, RankFactory#createRankStrategy - Storage values are read multiple times in a single function

Description

In the `RankStrategy` contract, the `initialize` function reads `creatorAddress` value twice from storage at the end of the function.

In the `RankFactory` contract, the `createRankStrategy` function reads `factorySettings.platformFees.ownerDepositFeeBP` and `factorySettings.backendAddress` values twice from storage.

Recommendation

Cache the storage value and use it instead of reading them multiple times in a single function.

Status

Resolved

QA

[Q-01] Contracts - Floating pragma

Description

The contracts use `pragma solidity ^0.8.20`.

This can allow the contracts to be deployed with the wrong pragma version which is different from the one the contracts were tested with.

Recommendation

Lock the pragma version.

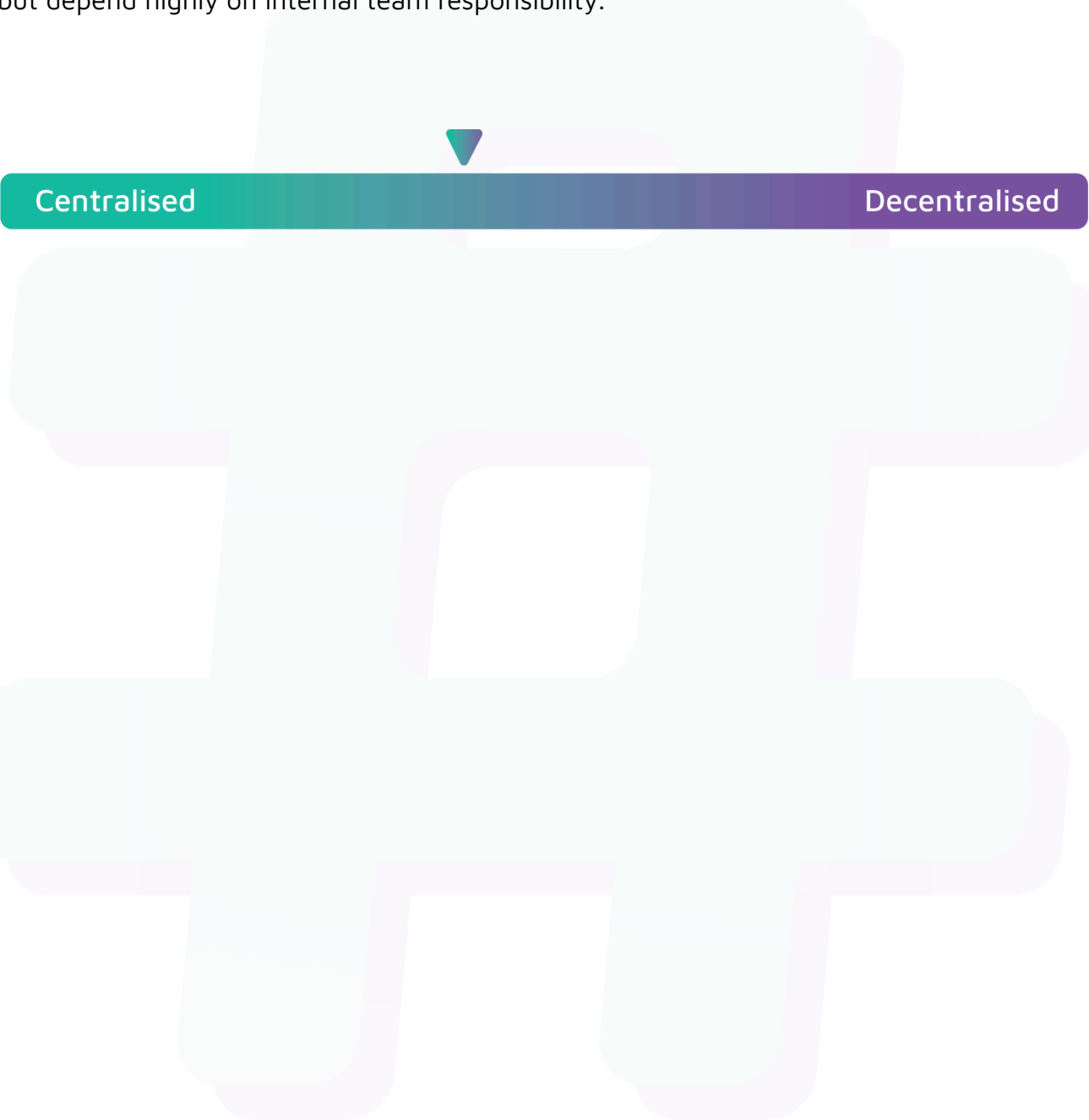
Status

Resolved

Centralisation

The Rank Trading project values security and utility over decentralisation.

The owner executable functions within the protocol increase security and functionality but depend highly on internal team responsibility.



Centralised

Decentralised

Conclusion

After Hashlock's analysis, the Rank Trading project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved and acknowledged. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.